



기업 환경에서의 AI 인터페이스와 MCP(Model Context Protocol) 보안

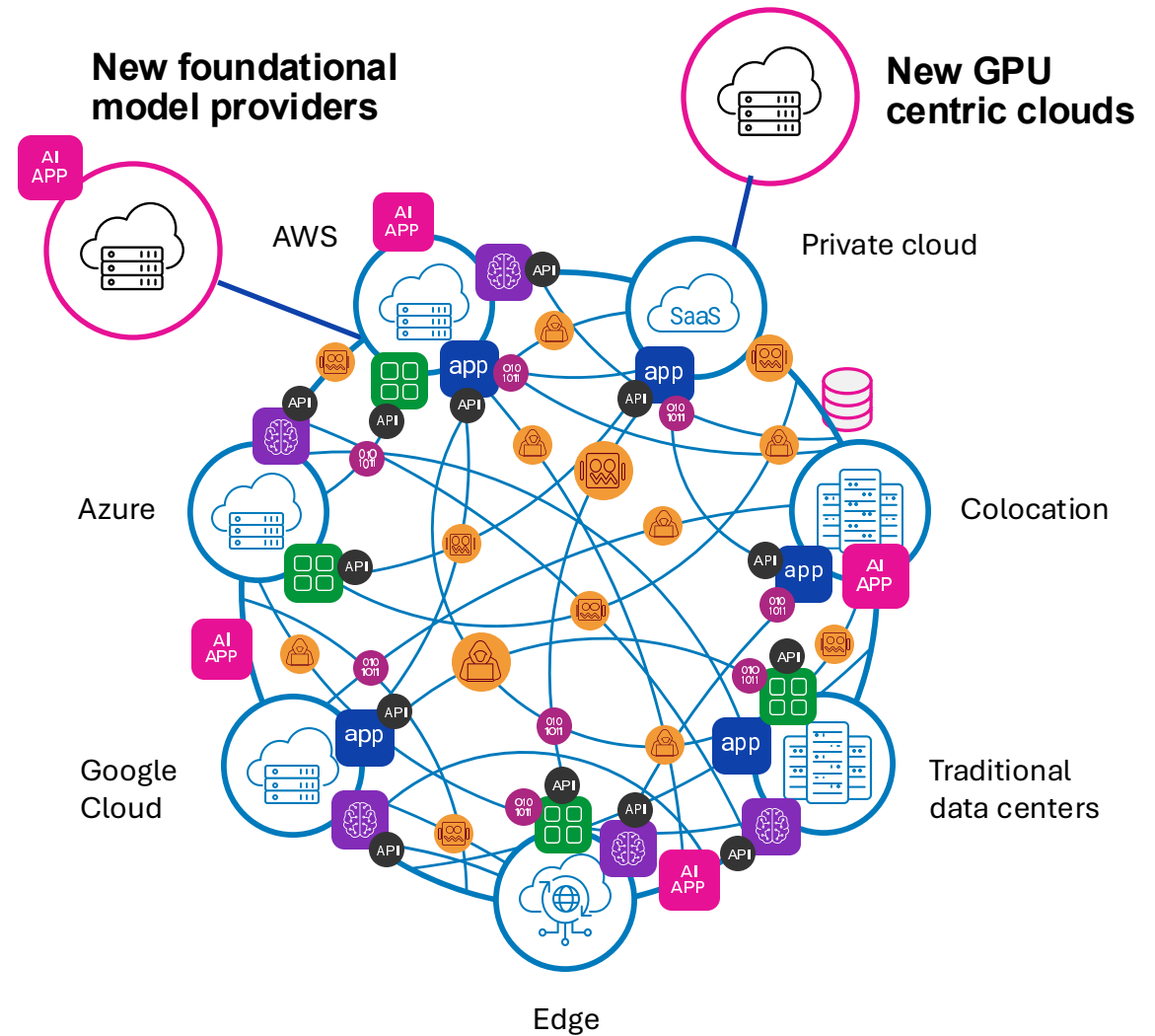
James Jinwon Lee / Senior Security Solution Architect / F5 APCJ

11 August 2025

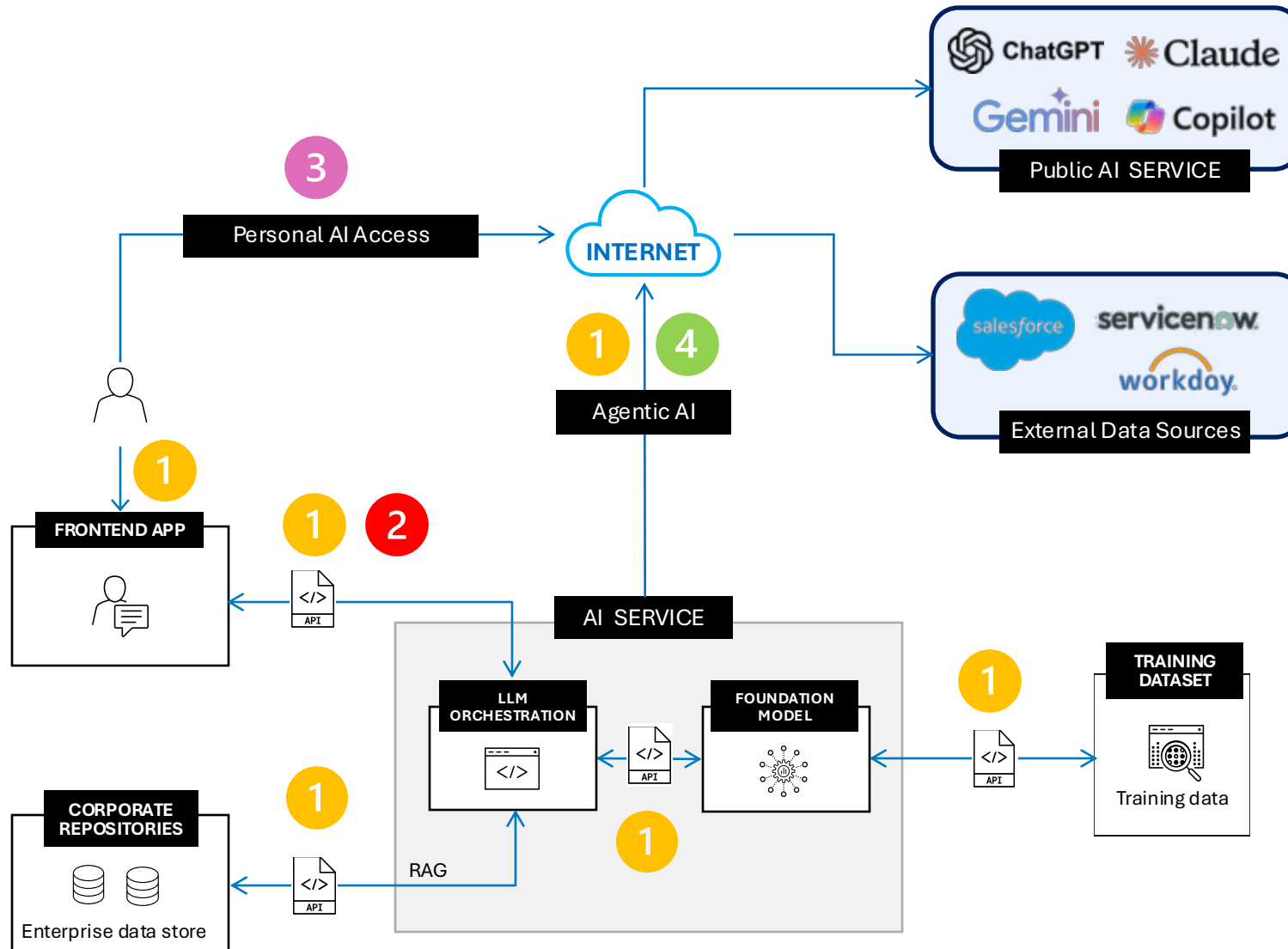
AI Security Landscape

Generative AI on the verge to make the multi-cloud complexity even more acute

- 1 Generative AI app experiences will be **multi-modal**
- 2 Generative AI apps will be highly **decomposed**
- 3 “**Data gravity**” will significantly influence placement of apps and models
- 4 Generative AI apps will be especially dependent on **APIs**



Security challenges in the AI ecosystem



1 API Security

- Ensure secure data exchange through API requests and responses.
- Continuously monitor and protect APIs.
- Mitigate risks outlined in the OWASP API Top 10.

2 LLM Security

- Monitor threats specific to LLMs, such as prompt injection and data leakage.
- Address vulnerabilities listed in the OWASP LLM Top 10.

3 Shadow AI Security

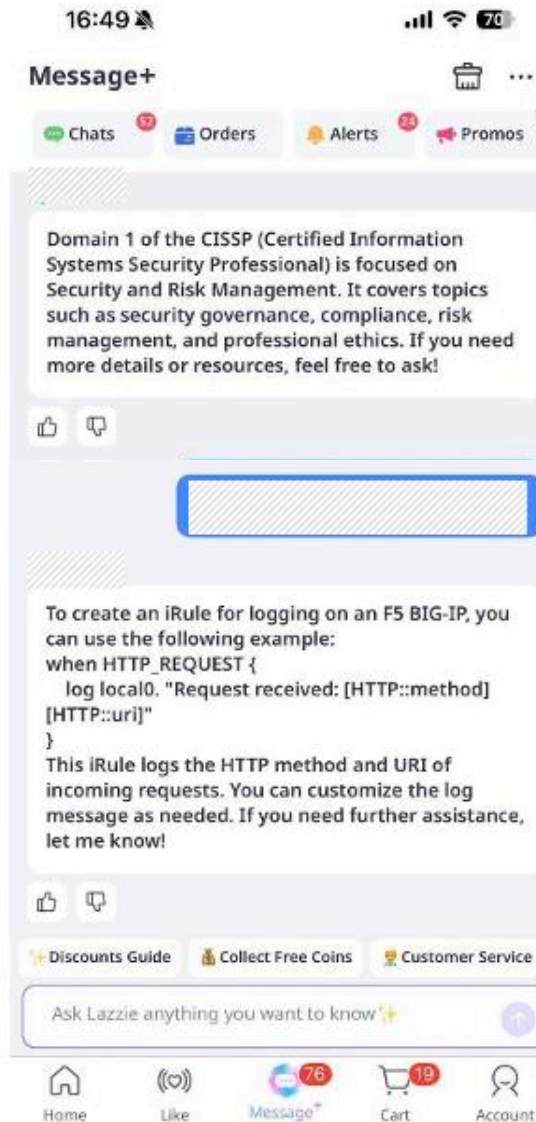
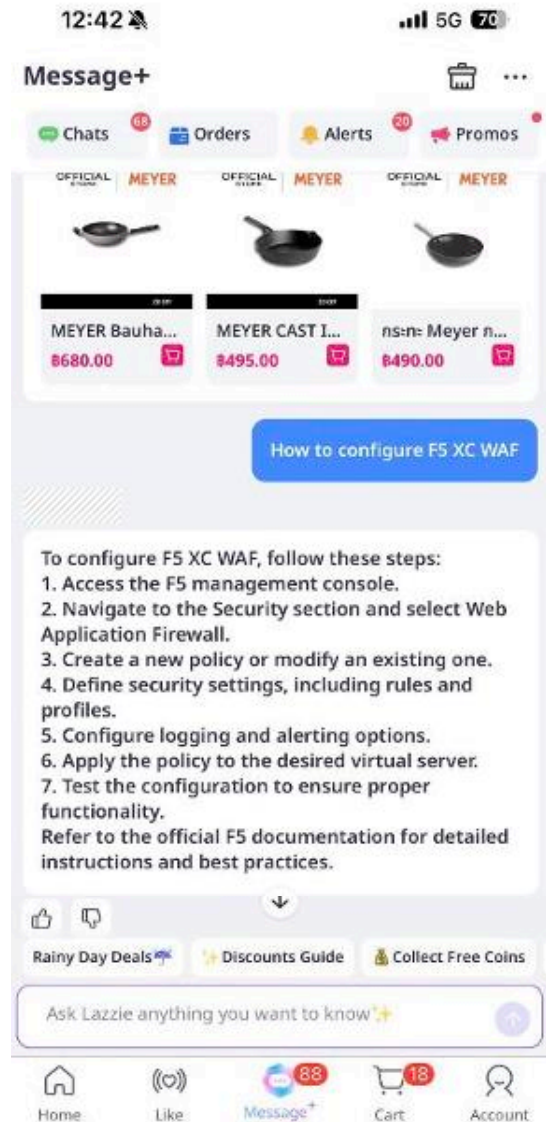
- Manage risks from employee use of public AI services like ChatGPT, Gemini, and others.
- Monitor for potential data leakage and unauthorized access.

4 Egress Traffic Control

- Secure outbound API traffic initiated by agentic AI systems, including MCP servers.
- Enforce dynamic policies to control and govern egress behavior.

Addressing Emerging AI Threats with F5 AI Gateway

How much secure your AI app?



What is 'AI Gateway'?

Securing and Protecting API Connections to AI Providers

Innovation Insight: AI Gateways

Published: 07 November 2024

Summary

AI gateways manage, secure and protect API connections to AI providers. Software engineering leaders can use AI gateways to apply security; multi-LLM routing; cost visibility; and data protection, scanning and risk mitigation controls to their AI usage.

The Gartner logo is displayed in a large, blue, sans-serif font. The letter 'G' is significantly larger than the other letters and has a dark blue shadow effect. A registered trademark symbol (®) is located at the end of the word.

AI-powered applications are...

AI applications are also modern apps, but they introduce new security threats

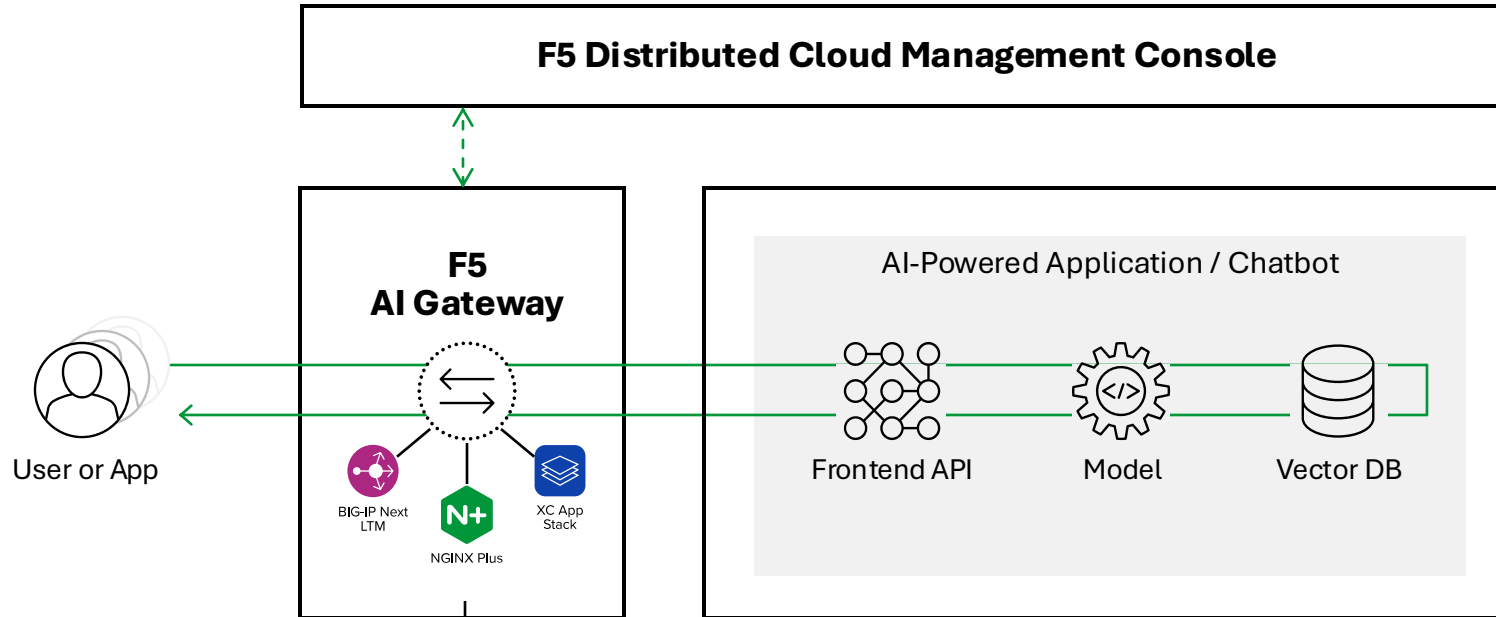
Built as modern applications...

- Containerized workloads in Kubernetes, hosted in public cloud (not withstanding highly regulated verticals)
- Built with JSON/REST and GraphQL APIs
- Operated with a high degree of automation (CI/CD, DevOps)
- Managed with a product mindset with fast iterations and frequent changes

with specific concerns and challenges

- Data loss prevention (DLP) and PII compliance
- Disparate, regional AI governance legislation
- Cost control for both local and external/public LLMs
- Fine-grained access control for LLMs and DBs and RAG
- New threat vectors using LLMs as a new attack surface

Introducing F5 AI Gateway



Policy Enforcement

- Full inspection of prompt and response
- Sanitization and redaction of data
- Data leak prevention
- Fine-grained access control to data
- LLM-selection and cost optimization
- Prevention of unauthorized outputs
- Detection/prevention of attacks on LLMs



**Application,
Security and Infra
Teams**



**Accelerate,
Protect and
Observe AI Apps**



**On BIG-IP, NGINX
and XC**

F5 AI Gateway

AI Model Routing and Data Security



AI traffic security

Inspection of all inbound and outbound traffic to AI LLM and SLM models to mitigate risks effectively.



Data leakage protection

Identify and protect customer PII, and sensitive enterprise data from exfiltration.



Enterprise security architecture

Enforce authentication, authorization, RBAC, and credential management with audit log exports for compliance.



Seamless AI integrations

Connect and route traffic to OpenAI, Anthropic, Ollama, and upstream HTTP services seamlessly.



Customizable operations

Leverage Python SDK to create tailored policies for traffic inspection based on organizational needs.



Enhanced observability and governance

Automated OpenTelemetry data exports to SIEM/SOAR systems for metrics and trace observability.



Optimized AI resource consumption

Route requests to high- or low-cost models based on origin, content, and context.

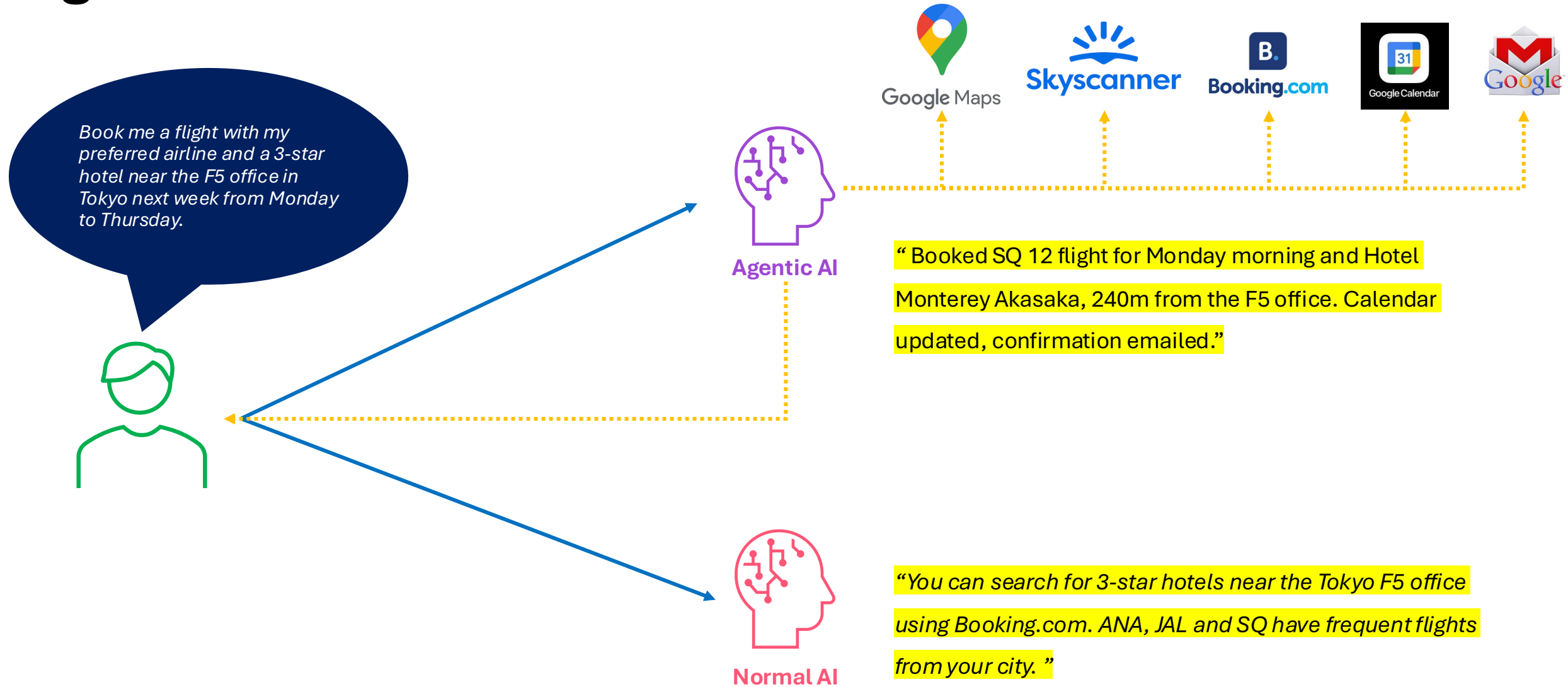


Model routing

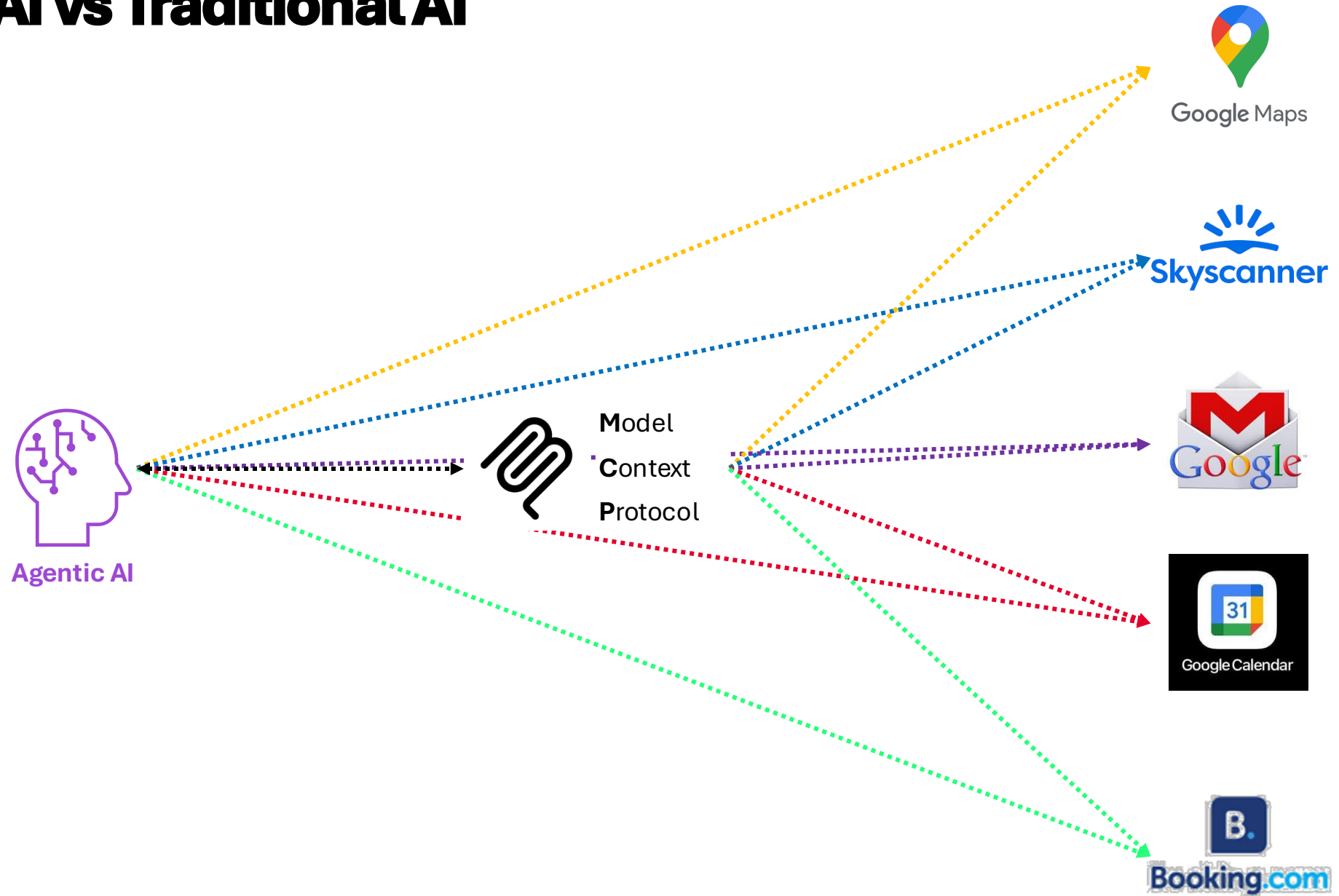
Route AI prompts to the ideal model based on cost or use case, optimizing efficiency and scalability.

Securing MCP (Model Context Protocol) for Agentic AI Systems

Agentic AI vs Traditional AI

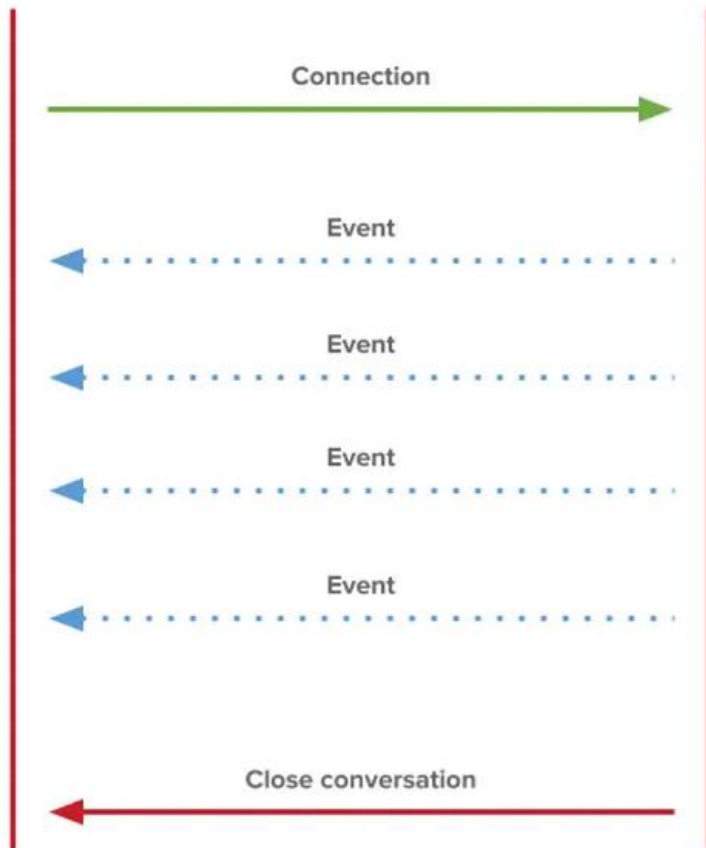


Agentic AI vs Traditional AI

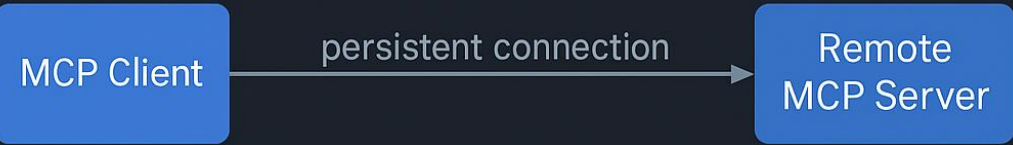


Streamable HTTP MCP vs SSE(Server Sent Event) MCP

Server-sent Events (SSE)

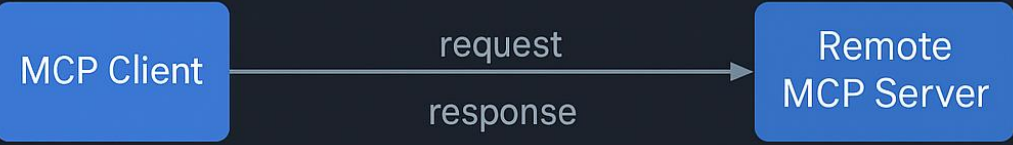


SSE



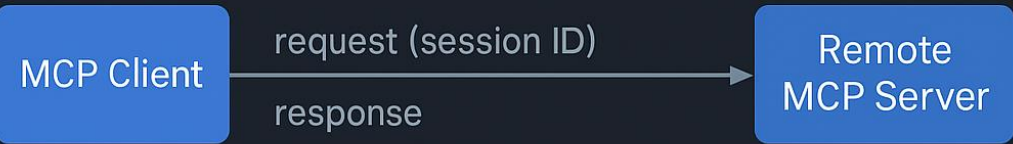
Streamable HTTP

no session tracking



Streamable HTTP

with session tracking



SSE(Server Sent Event) MCP

```
GET /sse HTTP/1.1
host: 44.44.44.1:8080
connection: keep-alive
Accept: text/event-stream
accept-language: *
sec-fetch-mode: cors
user-agent: undici
pragma: no-cache
cache-control: no-cache
accept-encoding: gzip, deflate

HTTP/1.1 200 OK
Content-Type: text/event-stream
Cache-Control: no-cache
Connection: keep-alive
Date: Fri, 11 Apr 2025 21:44:06 GMT
Transfer-Encoding: chunked

50
event: endpoint
data: /messages?sessionId=0aecc531-54c1-4460-a64a-9867806af0ea

d1
event: message
data: {"result":{"protocolVersion":"2024-11-05","capabilities":{"tools":{},"resources":{},"prompts":{},"logging":{},"serverInfo":{"name":"Addition","version":"1.0.0"}},"jsonrpc":"2.0","id":0}

74
event: message
data: {"jsonrpc":"2.0","method":"sse/connection","params":{"message":"SSE Connection established"}}

3f
event: message
data: {"method":"ping","jsonrpc":"2.0","id":0}

3f
event: message
data: {"method":"ping","jsonrpc":"2.0","id":1}

3f
event: message
data: {"method":"ping","jsonrpc":"2.0","id":2}

3f
event: message
data: {"method":"ping","jsonrpc":"2.0","id":3}
```

Streamable HTTP MCP

```
POST /mcp HTTP/1.1
Host: 10.144.73.189:8123
Connection: keep-alive
Content-Length: 204
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/135.0.0.0 Safari/537.36
accept: application/json, text/event-stream
content-type: application/json
Origin: http://10.144.75.185:5173
Referer: http://10.144.75.185:5173/
Accept-Encoding: gzip, deflate
Accept-Language: en-US,en;q=0.9
dnt: 1
sec-gpc: 1

{"method":"initialize","params":{"protocolVersion":"2024-11-05","capabilities":{"sampling":{},"roots":{"listChanged":true}},"clientInfo":{"name":"mcp-inspector","version":"0.7.2"}}, "jsonrpc":"2.0","id":0}
HTTP/1.1 200 OK
X-Custom-Header: value
Access-Control-Allow-Origin: *
Access-Control-Allow-Methods: GET, POST, DELETE, OPTIONS
Access-Control-Allow-Headers: Content-Type, Accept, Authorization, x-api-key, Mcp-Session-Id, Last-Event-ID
Access-Control-Expose-Headers: Content-Type, Authorization, x-api-key, Mcp-Session-Id, Mcp-Session-Id
Access-Control-Allow-Credentials: true
Mcp-Session-Id: d8dd10cb-7606-404f-bd93-e1eeb8541f1c
Content-Type: application/json
Date: Sat, 19 Apr 2025 05:05:36 GMT
Connection: keep-alive
Keep-Alive: timeout=5
Transfer-Encoding: chunked

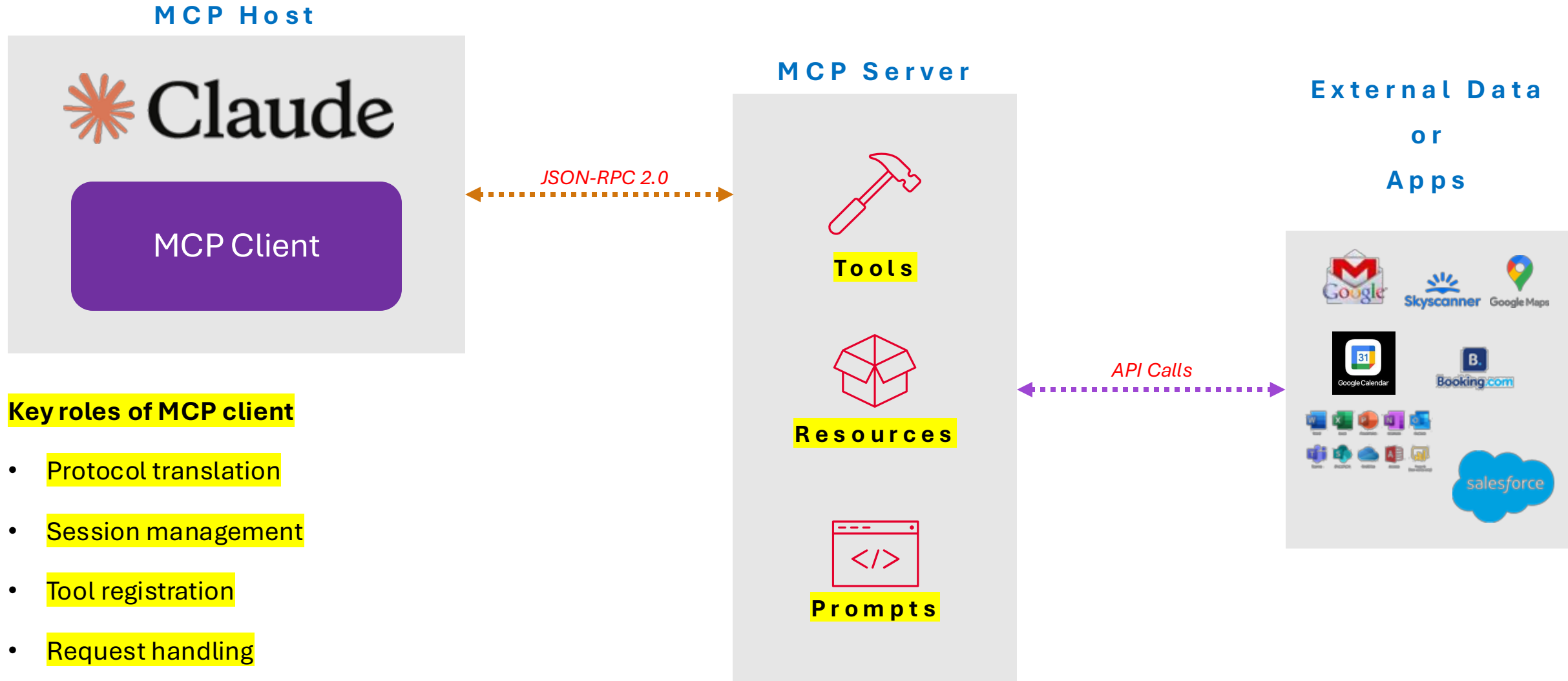
9c
[{"result":{"protocolVersion":"2024-11-05","capabilities":{"tools":{},"serverInfo":{"name":"ravikiran-mcp-poc","version":"0.0.1"}}, "jsonrpc":"2.0","id":0}]
0

POST /mcp HTTP/1.1
Host: 10.144.73.189:8123
Connection: keep-alive
Content-Length: 54
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/135.0.0.0 Safari/537.36
accept: application/json, text/event-stream
content-type: application/json
mcp-session-id: d8dd10cb-7606-404f-bd93-e1eeb8541f1c
Origin: http://10.144.75.185:5173
Referer: http://10.144.75.185:5173/
Accept-Encoding: gzip, deflate
Accept-Language: en-US,en;q=0.9
dnt: 1
sec-gpc: 1

{"method":"notifications/initialized","jsonrpc":"2.0"}
HTTP/1.1 202 Accepted
X-Custom-Header: value
Access-Control-Allow-Origin: *
Access-Control-Allow-Methods: GET, POST, DELETE, OPTIONS
Access-Control-Allow-Headers: Content-Type, Accept, Authorization, x-api-key, Mcp-Session-Id, Last-Event-ID
Access-Control-Expose-Headers: Content-Type, Authorization, x-api-key, Mcp-Session-Id, Mcp-Session-Id
Access-Control-Allow-Credentials: true
Date: Sat, 19 Apr 2025 05:05:36 GMT
Connection: keep-alive
Keep-Alive: timeout=5
Transfer-Encoding: chunked

0
```


MCP(Model Context Protocol) Architecture



Lack of Built-in Authentication/Authorization

No Native Authentication Enforcement in MCP Core

- MCP still lacks built-in support for OAuth flows or token-based authentication.

No Built-in Identity or Role Awareness

- MCP does not natively support user identity, roles, or session tracking.

No Granular Access Control or API Scoping

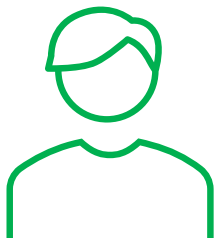
- MCP lacks RBAC, scopes, or group-based filtering out-of-the-box.

Unrestricted Tool Visibility and Invocation

- Once registered, all tools are callable unless manually restricted by developers.

Lack of Built-in Authentication/Authorization

Authorization Code Flow with PKCE(Proof-Key Code Exchange)
Access Token Handling (JWT processing)
Protected Resource Metadata – RFC9728
OAuth Resource Server Role



-
-
-

Base Protocol

Authorization

Copy page

11 Purpose and Scope

MCP clients to make requests to restricted MCP servers on behalf of resource owners. This

1.2 Protocol Requirements

Authorization is **OPTIONAL** for MCP implementations. When supported:

- Implementations using an HTTP-based transport **SHOULD** conform to this specification.
- Implementations using an STDIO transport **SHOULD NOT** follow this specification, and instead retrieve credentials from the environment.
- Implementations using alternative transports **MUST** follow established security best practices for their protocol.

1.3 Standards Compliance

This authorization mechanism is based on established specifications listed below, but implements a selected subset of their features to ensure security and interoperability while maintaining simplicity:

- OAuth 2.1 IETF DRAFT ([draft-ietf-oauth-v2-1-13](#))
- OAuth 2.0 Authorization Server Metadata ([RFC8414](#))
- OAuth 2.0 Dynamic Client Registration Protocol ([RFC7591](#))
- OAuth 2.0 Protected Resource Metadata ([RFC9728](#))



Lack of Built-in Authentication/Authorization

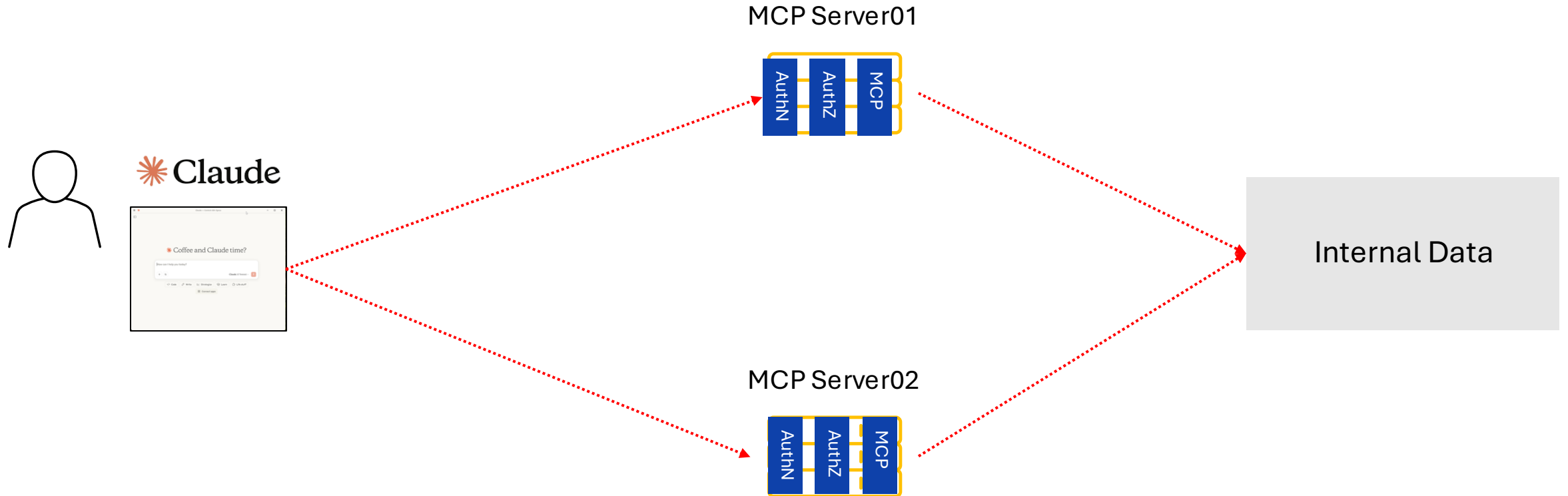
YES! The MCP specification now recommends OAuth 2.1 for secure deployments...however...

- *The core protocol still lacks native authentication or authorization enforcement.*
- *Security enforcement must be implemented externally, outside of MCP's core.*

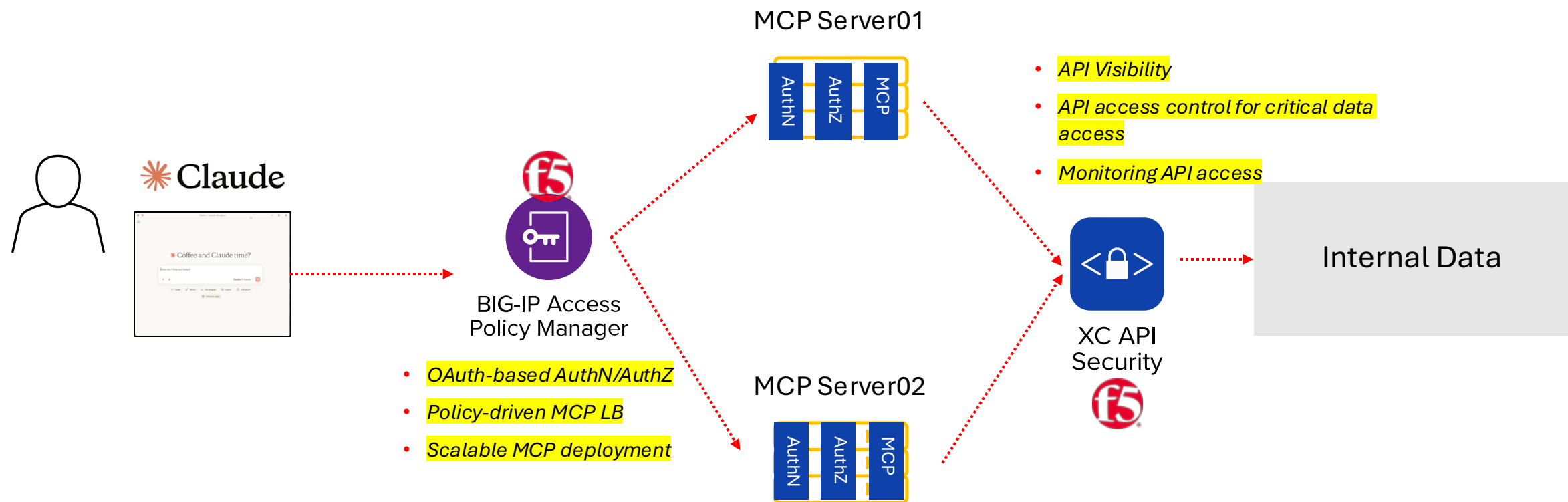


Security is your JOB!!

How F5 can help our customers?



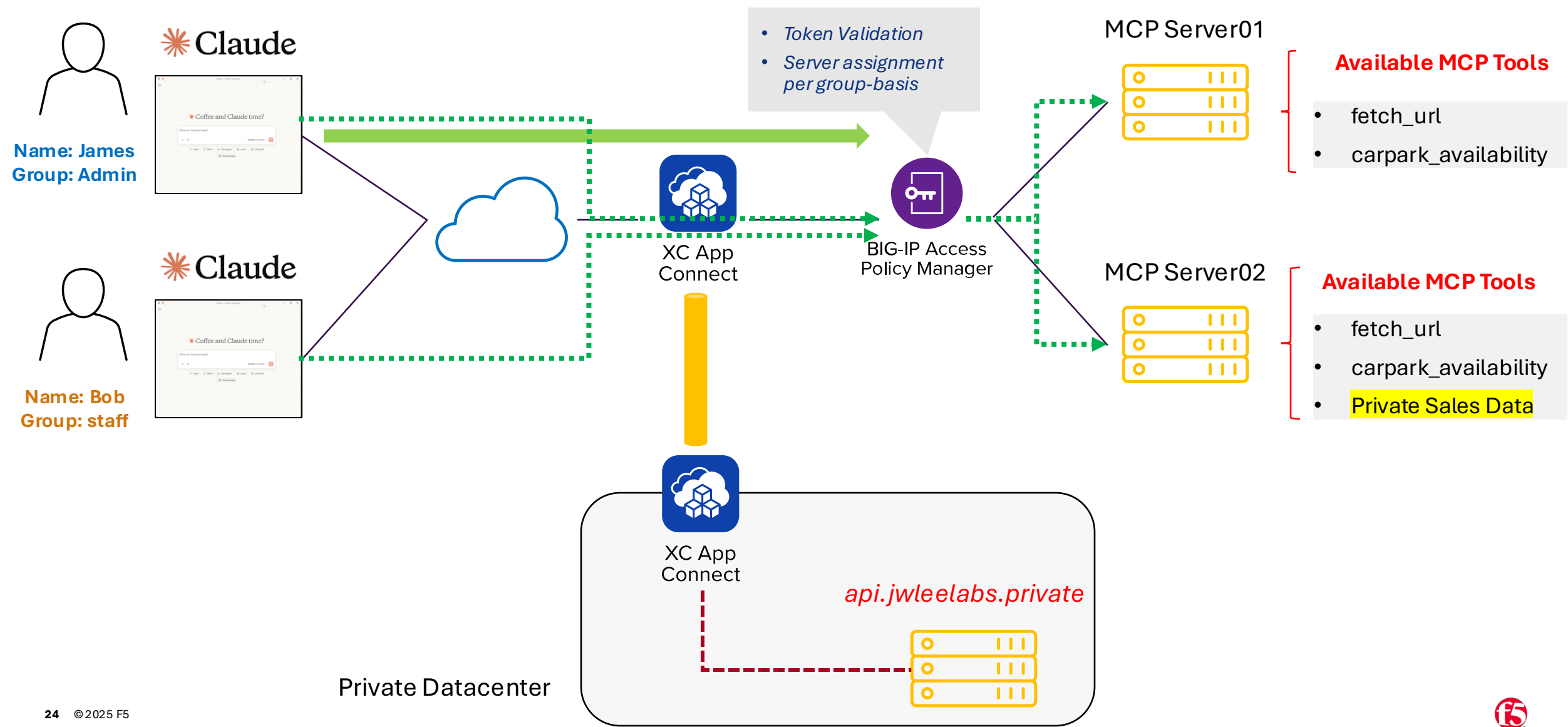
How F5 can help our customers?



Demo

Policy-Driven MCP Routing Based on User Group Identity

Policy-Driven MCP Routing Based on User Group Identity

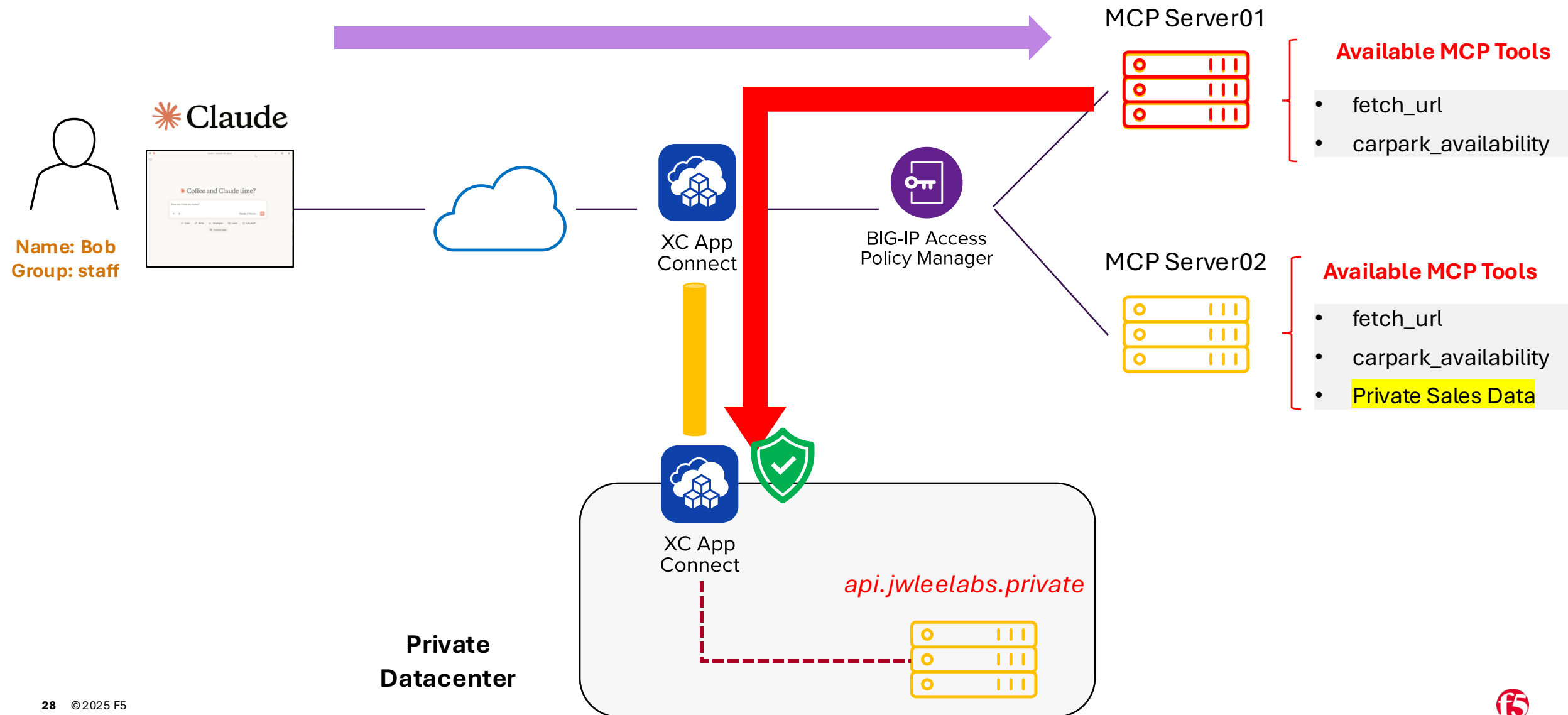


Demo Scenario

- 1) ACME Corporation provides a suite of MCP tools to support employees in using AI applications effectively.
- 2) One of these tools, the 'private_sales_tool', grants access to sensitive corporate data—including sales representatives' names, job titles, and performance metrics.
- 3) To protect this critical information, ACME executives have decided to restrict access to the 'private_sales_tool' to a specific internal group.
- 4) This ensures that regular users do not have access to confidential sales data.

Egress Access Control from Agentic AI

Securing Critical API Access from MCP Server



Demo Scenario

- 1) The user 'Bob' is not a member of the 'Admin' group.
- 2) As a result, he is only authorized to use the 'fetch_url' and 'get_carpark_availability' MCP tools and is restricted from accessing sensitive corporate data via the 'private_sales' MCP tool.
- 3) However, Bob is aware of the internal application's domain name.
- 4) He attempts to bypass access restrictions by using the 'fetch_url' tool—an MCP tool he is permitted to use—to indirectly access critical data.
- 5) Because 'fetch_url' is capable of retrieving content from remote applications, Bob abuses this functionality in an attempt to access unauthorized internal data, violating access control policies.

